

Fair Drop — Threat Model

Assets: ticket ownership (500), fairness of allocation, inventory integrity, session integrity, experiment credibility, platform quota. **Adversary:** an automated client operator with scripting skill, many requests, possibly many IPs (residential proxies), many accounts, a headless browser that can fake behavior, and possibly paid CAPTCHA-solving. Not in scope: Cloudflare compromise, our secrets being stolen.

Honesty rule: nothing here is "unexploitable". Each row states what the system actually guarantees and what remains.

#	Threat	Attack	Intended effect	Counter-mechanism	Residual weakness	Evaluation metric
T1	Request flooding	Thousands of register / reserve calls per second	More chances / exhaust capacity / crowd out humans	L0 edge limit, L1/L2 buckets, semantic dedupe (one entry per account), lottery ignores volume, risk NET_* rules	Distributed floods from many IPs consume Worker/DO request quota (free-tier exhaustion = availability attack). Cloudflare DDoS protection mitigates volumetric attacks, not quota burn on valid-looking requests	RVA, VS(A), rate_limited, blocked edge, lottery_entry_violation=0, P99 latency under flood
T2	Retry storm	Aggressive retries on 429/503/409	Win by persistence when the system sheds load	Server-dictated retry_after_ms, buckets, registration window long enough that shedding only delays, retries collapse to the same participant	Retrying clients get more latency priority for status reads (cosmetic only)	VS on retry_amplification, deduplicated, AAR
T3	Concurrent requests / race conditions	Parallel reserve / confirm for the same or different participants, timed at release	Double holds, oversell, two owners for one ticket	Single-threaded DO, transactionSync, partial unique indexes, natural-key idempotency, offer capacity invariant	A DO bug would break this (mitigated by continuous invariant check + HALTED). The DO is a single point of throughput (~ low thousands ops/s)	oversells, duplicate_allocations, inventory drift, invalid_reservations (all 0) under the race scenario
T4	Multiple sessions (same account)	Many browsers/sessions on one account	Multiply entries or holds	Participant keyed by account. Parallel-session risk rule. Account bucket L2	None for entries. Extra sessions only add load	duplicate_allocations=0, SES_PARALLEL hits
T5	Duplicate registrations	Re-register, email variants (a+1@ , a.b@gmail)	Multiple entries	Natural key + email normalization + email_hash unique	Distinct real mailboxes aren't detected (→ T11)	deduplicated, ineligible by reason.DUPLICATE_IDENTITY
T6	Fake human behavior	Headless browser synthesizing mouse curves, dwell times	Evade risk engine	Multi-category scoring. Network/session rules that are hard to fake cheaply. Turnstile escalation. Lottery still gives at most 1 entry per account even if detection is fully evaded	A good human-like bot on one account is indistinguishable from a human and gets exactly the human's odds. That is the designed worst case, not a failure	BAR vs HAR for HUMAN_LIKE_BOT (expected ≈ equal in FAIR), detection recall (model-dependent)

#	Threat	Attack	Intended effect	Counter-mechanism	Residual weakness	Evaluation metric
T7	Low-and-slow bots	Stay below all rate limits, behave plausibly	Avoid detection	Volume and speed confer nothing in the lottery, so slowness gains no advantage	Not detected. Gets equal odds per account	$BAR(SLOW_BOT) \approx HAR$. No advantage expected or claimed
T8	Refresh/reconnect abuse	Mass refresh, reconnect to reset state or re-roll	Reset a losing/expired state, get a new offer	State in DO keyed by account. Terminal states are final. NAV_REFRESH / SES_RECONNECT rules	Refresh storms cost requests (quota)	Refresh scenario: participant status unchanged, SES_RECONNECT hits
T9	Session/token reuse	Copy session cookie to other devices/workers, replay Turnstile tokens	Share one eligible identity or bypass challenge	HMAC cookie bound to <code>device_id</code> . Cross-device reuse → HARD_TOKEN_REUSE → revoke + RESTRICT. Turnstile tokens single-use, checked against <code>cdata=participant_id</code>	A cookie copied <i>with</i> its <code>device_id</code> (same <code>localStorage</code>) can't be distinguished. It still maps to one participant, so there's no gain in entries	<code>token_reuse</code> detections, <code>challenge_failed</code>
T10	Hold squatting	Winners (or bots) hold tickets and never confirm, to deny others	Waste inventory	Short hold TTL, offer TTL, expiry → AVAILABLE + waitlist promotion, one hold per participant	Inventory may go unsold if the waitlist is exhausted or the booking window ends	<code>expired_holds</code> , <code>promoted</code> , <code>unsold</code> at close
T11	Sybil / multi-account	Operator registers K accounts with distinct emails, devices, IPs	K lottery entries	Email normalization, device/network clustering signals, per-network registration risk, Turnstile per suspicious account	Not solvable without strong identity (verified phone, government ID, payment instrument, loyalty history). An operator with K independent-looking accounts gets $\approx K \times$ the odds. FAIR still removes <i>volume/speed</i> advantage, so cost scales with accounts, not requests	OWR, tickets per operator, <code>SES_SHARED_DEVICE</code> hits. MULTI_SESSION_BOT scenario reports per-operator outcome openly
T12	Seed manipulation by operator	Insider picks a seed or edits the pool after seeing results	Rig the lottery	Commit-reveal: commitment before registration, snapshot hash fixed at freeze, final seed bound to snapshot. Public audit recompute	The server knows <code>server_seed</code> before close and could <i>grind</i> inserted fake participants until a preferred outcome results. Mitigation options: public randomness beacon (drand)	Audit verify: commitment, snapshot, result hash

#	Threat	Attack	Intended effect	Counter-mechanism	Residual weakness	Evaluation metric
					mixed in after freeze (OD-4)	
T13	Sim/admin API abuse	Call <code>/sim/*</code> publicly, spoof <code>X-FD-Sim-Client</code> to dodge IP limits	Bypass controls, poison results	Admin cookie for creation. Scoped, expiring HMAC sim tokens. Virtual network header honored only on <code>kind=EXPERIMENT</code> drops. Experiment drops are separate DOs from public drops	Leaked admin passphrase = full sim control (no impact on the public drop's inventory)	Negative auth test suite
T14	Telemetry poisoning	Send forged "human" telemetry summaries	Lower risk score	Telemetry is one category capped at 35. Network/session features are server-observed. Telemetry can lower risk only by withholding negative interaction points, never subtract network points	A full forgery reduces the score by at most the interaction contribution	Ablation: risk with/without client telemetry
T15	Quota exhaustion (platform)	Push daily Worker/DO/D1 quotas to their limit	Take the demo down	Edge limits, batching, aggregated writes. Can move to Paid	On the Free tier this is a real availability risk	<code>budget.*</code> per run, daily quota dashboard

Guarantees vs non-guarantees

Guaranteed by construction (assuming correct implementation): I-1...I-7 and I-12. Specifically: no oversell, no double ownership, one entry per account, volume and speed don't enter allocation, idempotent retries, refresh-safe state, verifiable lottery given the commitment.

Probabilistic / best-effort: behavioral detection, Turnstile effectiveness, cross-account clustering.

Not provided: strong Sybil resistance, resistance to an operator who controls the server before freeze (partially mitigated by OD-4), availability against quota-exhaustion on the Free tier.